Informática Forense y Respuesta ante Incidentes

Tema 7. Análisis forense

Índice

Esquema

Ideas clave

7.1. Introducción y objetivos

7.2. Análisis de un S. O. Windows

7.3. Análisis de un S.O. Linux

7.4. Análisis de un S. O. MacOS

7.5. Referencias bibliográficas

A fondo

Windows Forensic Analysis Poster

How does Apple's M1 chipsets impact on imaging macs?

La práctica de la Informática Forense

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

7.1. Introducción y objetivos

Este tema no pretende abarcar todos los posibles análisis a los que nos podemos enfrentar, sino que expone cuáles son las **fuentes de información** más típicas dentro de los tres sistemas operativos más utilizados: **Windows, Linux y MacOS.**

Además de conocer cuáles son estas fuentes de información, también se verá la manera en que pueden ser adquiridas, el tipo de información que almacenan y por qué suelen ser de interés.

Los objetivos de este tema son:

- Exponer las fuentes de información más típicas dentro de los sistemas operativos Windows, Linux y MacOS.
- Conocer cómo realizar el análisis forense de equipos con Sistemas Operativos Windows, Linux y MacOS.

© Universidad Internacional de La Rioja (UNIR)

7.2. Análisis de un S. O. Windows

El tipo de información que podemos recolectar y estudiar dentro de un Sistema Operativo Windows es mucha y muy variada por lo que nos centraremos en:

- 1. Recolección de la información volátil.
- 2. El Registro de Windows.
- 3. El registro de eventos.
- 4. La actividad reciente.
- 5. La papelera de reciclaje.

Recolección de información volátil

Todos los sistemas operativos manejan gran cantidad de información volátil, la cual se pierde al apagar el equipo. Por lo tanto, únicamente vamos a poder recolectar esta información si nos encontramos ante un equipo Windows encendido.

Una muestra de la información volátil que podemos encontrar en un Sistema Operativo Windows que nos será de interés desde un punto de vista forense es:

- La fecha y la hora del sistema.
- Los usuarios que han iniciado sesión.
- Información sobre los archivos abiertos.
- Información de red.
- Procesos en ejecución.

© Universidad Internacional de La Rioja (UNIR)

- Etc.

Fecha y hora del sistema

Aunque pueda parecer obvio, uno de los primeros pasos cuando comenzamos a trabajar sobre un equipo encendido es obtener la fecha y hora del sistema. De esta forma podremos comprobar si se encontraba correctamente configurada o si, por el contrario, había sido modificada.

El conocer la fecha y hora configurada en el sistema nos permitirá construir una línea temporal fidedigna; y, de esta forma, evitar posibles manipulaciones intencionadas por parte del usuario.

Si tenemos acceso al equipo, podemos obtener la fecha y hora del sistema desde la consola de comandos y desde la consola de PowerShell.

Desde la consola de comandos, utilizando el comando «date /t & time/t», obtendremos la fecha y hora local de la máquina. Por su parte, desde PowerShell utilizando el comando «Get-Date» obtendremos la misma información.

Usuarios que han iniciado sesión

Durante la investigación es muy importante conocer los usuarios conectados al sistema objeto del análisis. Esto no incluye únicamente a los usuarios con acceso local, sino también a aquellos usuarios conectados de manera remota al equipo (por ejemplo, a través de un recurso compartido).

Para ello, las herramientas PsLoggedOn o LogonSessions, pertenecientes a las SysInternals de Microsoft son una muy buena opción.

Se puede acceder a ellas a través del siguiente link: https://docs.microsoft.com/en-us/sysinternals/.

También podemos obtener información muy relevante utilizando los propios

© Universidad Internacional de La Rioja (UNIR)

comandos del Sistema Operativo o las funciones incluidas en PowerShell.

Usuarios que han iniciado sesión: PsLoggedOn

PsLoggedOn es una herramienta que muestra tanto a los usuarios conectados localmente como a los usuarios conectados a través de los recursos de la computadora local o de una remota.

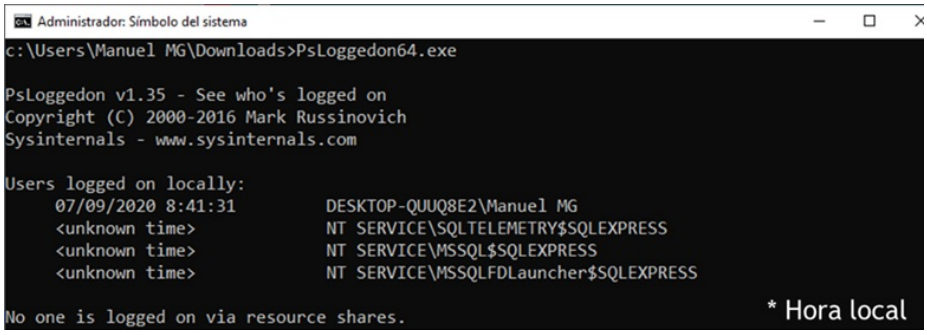


Figura 1. Ejecución del comando PsLoggedon. Fuente: elaboración propia.

Usuarios que han iniciado sesión: LogonSessions

Enumera las sesiones actualmente activas y, si se especifica la opción -p, los procesos que se están ejecutando en cada sesión.

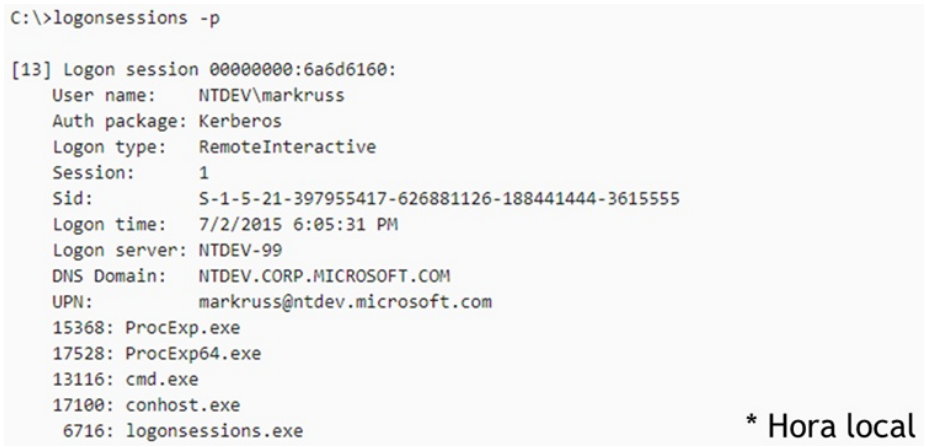


Figura 2. Ejecución del comando logonsessions. Fuente: Microsoft.

© Universidad Internacional de La Rioja (UNIR)

Usuarios que han iniciado sesión: CMD y PowerShell

También es posible obtener el listado de usuarios que han iniciado sesión en el equipo desde PowerShell utilizando el comando «query user /server:$SERVER».

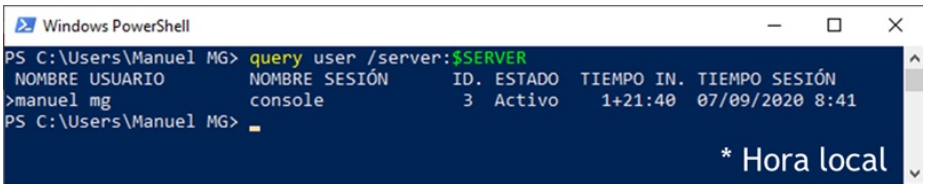


Figura 3. Ejecución del comando. Fuente: elaboración propia.

Archivos abiertos

Conocer los archivos abiertos por los usuarios que han iniciado sesión en el equipo puede aportar pistas muy importantes de cara a la investigación. Podemos, por ejemplo, ver los archivos compartidos que un usuario remoto ha abierto, archivos que pueden contener información confidencial que no debería salir de la organización.

De nuevo, una utilidad incluida en las SysInternals de Microsoft, PsFile, puede sernos de utilidad en este caso. Además, los comandos *net file* y *openfiles* también van a aportarnos información al respecto.

Otra opción sería ver los archivos abiertos por determinados procesos, pero eso lo veremos más adelante.

Archivos abiertos: PsFile

El comando *net file* muestra una lista de archivos que otros equipos han abierto en el local. Sin embargo, trunca los nombres de las rutas largas, y no permite ver esa información para los sistemas remotos. PsFile corrige esto y, además, permite cerrar los archivos abiertos.

Archivos abiertos: *openfiles*

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El comando *openfiles* permite a un administrador listar o desconectar archivos y directorios que se han abierto en un sistema.

Es necesario tener activada la opción «mantener lista de objetos» para poder ver los archivos abiertos localmente.

Información de red

Cuando se está investigando un incidente, las trazas de las comunicaciones de red suelen ser una gran fuente de información. Sobre todo, en casos relacionados con infecciones por *malware* o fugas de información.

En estos casos, la caché de conexiones realizadas mediante NetBIOS o las conexiones abiertas en el equipo, son los principales artefactos que investigar.

Información de red: información general

Antes de comenzar a obtener información sobre las conexiones establecidas, es necesario obtener la propia configuración de los interfaces de red del equipo.

Para ello, podemos utilizar las propias herramientas del sistema, como el comando *ipconfig (ipconfig /all)* o herramientas externas como PromiscDetect o Promqry que nos permiten detectar aquellos interfaces de red en modo promíscuo.

También podemos utilizar *scripts* de PowerShell para obtener esta información.

© Universidad Internacional de La Rioja (UNIR)

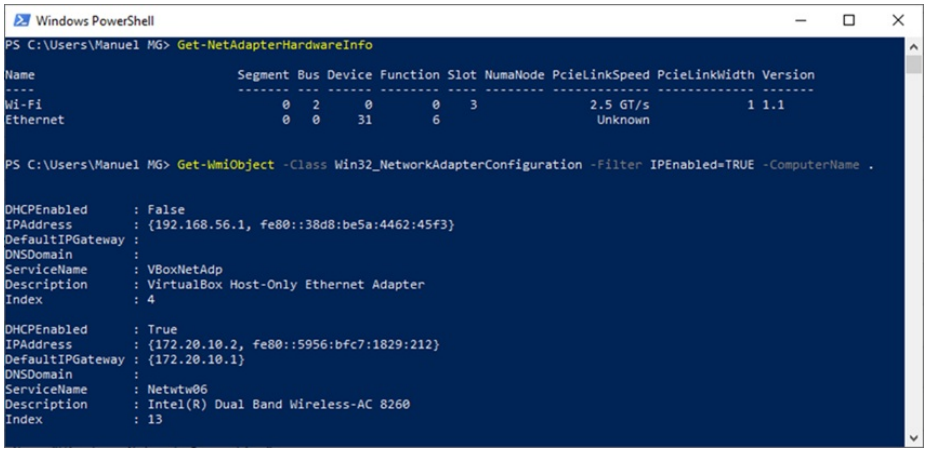


Figura 4. Ejecución de los comandos. Fuente: elaboración propia.

Información de red: caché NetBIOS

NetBIOS es un protocolo de red (cada vez menos utilizado, pero todavía activo) que permite a las aplicaciones comunicarse a través de la red.

La *caché* de nombres de NetBIOS contiene un listado de las conexiones realizadas por otros sistemas que utilizan este protocolo. Esta *caché* contiene el nombre y la dirección IP del sistema remoto, y podemos visualizarla utilizando el comando nbtstat incluido en el sistema operativo.

Para visualizar la *caché* de nombres de NetBIOS, tan solo tendremos que ejecutar el comando con la opción «-c»:

nbtstat -c

Información de red: conexiones abiertas

Cuando estamos analizando un equipo que sospechamos se encuentra infectado con un *malware,* uno de los primeros puntos a analizar es el de las conexiones abiertas. Las conexiones que dicho equipo tiene establecidas con otros sistemas (ejemplo, conexiones con el centro de control del *malware* o conexiones con el

© Universidad Internacional de La Rioja (UNIR)

sistema de *keylogger* remoto).

Para ello, podemos utilizar el comando netstat del propio sistema operativo y la herramienta TCPView de las SysInternals, la cual nos mostrará las conexiones establecidas por cada uno de los procesos en ejecución en el equipo.

Netstat es una herramienta en línea de comandos que muestra un listado con las conexiones activas en un equipo, tanto entrantes como salientes.

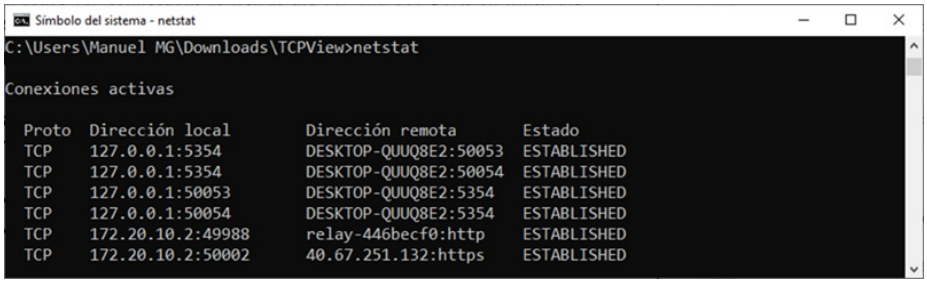


Figura 5. Ejecución de netstat. Fuente: elaboración propia.

Esta herramienta podemos ejecutarla con distintos parámetros, cada uno de los cuales nos mostrará una información u otra.

Por ejemplo, si añadimos la opción «-r», podemos visualizar las tablas de enrutamiento y rutas activas, mientras que con la opción «-o» podemos obtener los puertos y las direcciones remotas con las que se está comunicando un proceso (obtenemos su PID).

Procesos en ejecución

Los procesos que se encuentran en ejecución y la manera en que estos han sido «lanzados» son también importantes de cara a una investigación.

Analizando los procesos en ejecución, podemos saber, por ejemplo, si se están

© Universidad Internacional de La Rioja (UNIR)

utilizando los recursos de la empresa para minar criptomonedas o si algún equipo está infectado con un *software* malicioso.

La manera más sencilla de ver los procesos en ejecución es a través del administrador de tareas, pero desde un punto de vista más forense; de nuevo, las SysInternals de Microsoft nos proporcionan algunas herramientas muy útiles.

Procesos en ejecución: Tasklist

El comando *tasklist,* incluido en los Sistemas Operativos Windows, es una especie de administrador de tareas en modo consola de comandos. Esto nos permite automatizar esta parte de la recolección de evidencia, además de otras opciones interesantes como:

- /S [sistema]: especifica el sistema remoto al que conectarse.
- /U [dominio\usuario]: especifica el contexto de usuario.
- /SVC: muestra los servicios hospedados en cada proceso.
- /FI [filtro]: permite filtrar el listado.
- /FO [formato]: permite dar formato al listado.

Procesos en ejecución: *tasklist*

Similar al comando *tasklist,* la utilidad *pslist,* incluida en las SysInternals, muestra información básica de los procesos.

Para obtener información más precisa o avanzada, podemos utilizar algunas de sus opciones que, entre otras cosas, nos permiten ver en qué estado se encuentran los hilos asociados a los procesos o ver el listado en forma de árbol para apreciar a simple vista qué subprocesos se han lanzado y cuáles son los padres de estos subprocesos.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Procesos en ejecución: Process Explorer

Process Explorer es otra utilidad de Microsoft incluida en las SysInternals que nos permite ver el listado de procesos en ejecución en el equipo de manera mucho más amigable.

Con Process Explorer vamos a poder ver los procesos y subprocesos, los parámetros de ejecución de estos, las DLL utilizas, sus «punteros» *(handles)* en uso, etc.

Procesos en ejecución: Process Monitor

Process Monitor es una herramienta de supervisión para Windows que muestra en tiempo real la actividad del sistema de archivos, el registro, la red y los procesos.

Además, Process Monitor permite realizar un rápido filtrado de la información, lo que nos permite centrarnos únicamente en el proceso sospechoso (por ejemplo, un *keylogger)* y descartar el resto o analizar tan solo los archivos o las claves de registro que están siendo accedidas y/o modificadas.

Procesos en ejecución: ListDLL

ListDLLs es una utilidad que nos muestra las DLLs cargadas por los procesos.

Podemos utilizarla para listar todas las DLLs cargadas en todos los procesos, en un proceso específico; o, para listar los procesos que tienen una DLL cargada en particular. Por ejemplo, cuando sospechamos de una DLL maliciosa.

© Universidad Internacional de La Rioja (UNIR)

ListDLL también puede mostrar la información de la versión completa de las DLL, incluida su firma digital, y puede utilizarse para escanear procesos en busca de DLL no firmadas.

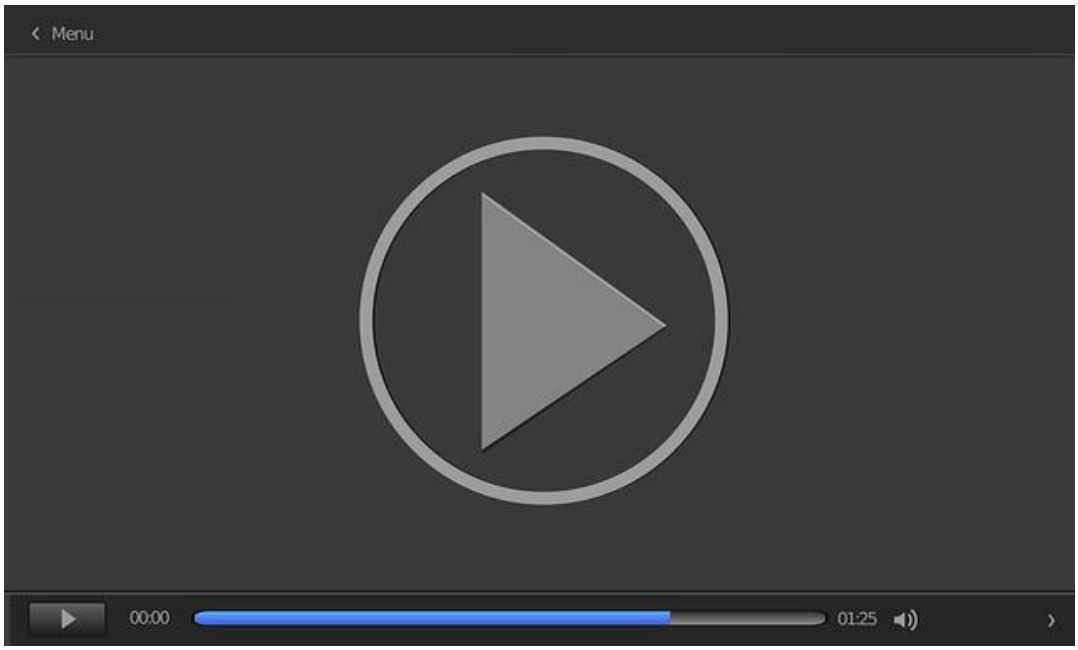
Procesos en ejecución: volcado de procesos

Aunque lo veremos más en profundidad cuando analicemos la memoria RAM, si hemos detectado un proceso malicioso, el siguiente paso sería realizar un volcado de la memoria de este.

Para ello podemos utilizar herramientas como:

- El propio Administrador de tareas (clic derecho sobre el proceso y «Crear archivo de volcado»).
- pmdump (existe en versiones para Windows y Linux/Android).
- ProcDump (incluido en las SysInternals).

En el siguiente vídeo, trataremos la herramienta Volatility, herramienta de código abierto:



© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=d6ace1ef-9022-46fb-a975-b19c00b92d1a

El registro de Windows

El registro de Windows es una gran base de datos jerárquica utilizado en los Sistemas Operativos Windows con el fin de almacenar información necesaria para configurar el sistema para los usuarios, las aplicaciones y los dispositivos de *hardware.*

El registro reemplaza a la mayoría de los archivos de configuración basados en texto que se utilizaban en los antiguos Windows 3.x y MS-DOS, como Autoexec.bat y Config.sys, y contiene información que Windows utiliza de manera recurrente, como, por ejemplo:

- Los perfiles de los usuarios.
- Las aplicaciones instaladas en el equipo.
- Los tipos de documentos que cada aplicación puede crear.
- Los elementos de *hardware* que hay en el sistema.
- Los puertos que se están utilizando.

El registro se estructura en forma de árbol, y contiene dos elementos básicos: **claves y valores.**

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Las **claves del registro** son similares a carpetas: además de los valores, cada clave puede contener subclaves que, a su vez, pueden contener más subclaves; y, así, sucesivamente.

Las claves están referenciadas con una sintaxis parecida a los nombres de las rutas de Windows, y usan barras diagonales inversas para indicar los distintos niveles jerárquicos.

Cada subclave tiene obligatoriamente un nombre: una cadena que no puede contener barras diagonales inversas y en la que no se distingue entre mayúsculas y minúsculas.

Hay cuatro claves raíz. Si visualizamos el registro con RegEdit veremos una quinta clave raíz: HKEY_CLASSES_ROOT. Esta clave muestra la información existente en:

- HKEY_LOCAL_MACHINE\SOFTWARE\Classes y
- HKEY_CURRENT_USER\SOFTWARE\Classes) dentro del registro de Windows y cada una de estas claves se almacena en uno o varios archivos distintos.

Las claves son:

- HKEY_CURRENT_USER.
- HKEY_LOCAL_MACHINE.
- HKEY_USERS.
- HKEY_CURRENT_CONFIG.

El registro se almacena en una serie de archivos dentro de la estructura de carpetas del sistema Windows.

La mayoría de estos archivos, excepto los asociados a la clave HKEY_CURRENT_USER, están en la carpeta de configuración del sistema:

© Universidad Internacional de La Rioja (UNIR)

- %SystemRoot%\System32\Config.

Mientras que el archivo correspondiente a la clave HKEY_CURRENT_USER está en la carpeta del usuario: Users\[Usuario].

Los archivos que almacenan la información de cada una de las claves raíz del registro de Windows son:

- HKEY_CURRENT_USER: archivos NTUSER.DAT ubicados en la raíz de la carpeta del usuario (Users\[Usuario]).
- HKEY_LOCAL_MACHINE: archivos SAM, SECURITY, SOFTWARE y SYSTEM ubicados en %SystemRoot%\System32\Config.
- HKEY_USERS: es un puntero a los archivos NTUSER.DAT de los usuarios que han iniciado sesión en el equipo.
- HKEY_CURRENT_CONFIG: es un puntero a HKEY_LOCAL_MACHINE\ SYSTEM\CurrentControlSet\CurrentControlSet\Hardware Profiles.

El registro de Windows es capaz de almacenar multitud de información relevante desde un punto de vista forense.

Ya que es prácticamente imposible conocer todo lo que de él podemos obtener, suelen utilizarse herramientas de terceros para interpretarlo. Herramientas como: Windows Registry Recovery, RegRipper y Registry Explorer son algunas de las más utilizadas para realizar esta tarea.

Dispositivos USB conectados

El listado de dispositivos USB conectados al equipo es una de las cosas que podemos obtener analizando el registro de Windows.

Esta información la encontramos analizando las claves de registro:

© Universidad Internacional de La Rioja (UNIR)

- SYSTEM/CurrentControlSet/Enum/USBSTOR y /USB.
- SYSTEM/MountedDevices.
- NTUSER.DAT/Software/Microsoft/Windows/CurrentVersion/Explorer/MountPoints2 (por cada usuario del sistema).

Además, fuera del registro de Windows también podemos encontrar esta información en el archivo: Windows/inf/setupapi.dev.log.

Como analizar y dar sentido a todos estos artefactos puede llevarnos un tiempo, lo más normal es utilizar herramientas que automaticen esta tarea como: USBDeview o USB Forensic Tracker.

Unidades de red mapeadas y recursos compartidos

Del análisis del registro del Sistema Operativo también podemos obtener las unidades de red mapeadas, tan solo accediendo a la clave: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\Map Network Drive MRU.

Además, la clave: NTUSER.DAT/Software/Microsoft/Windows/ CurrentVersion/Explorer/MountPoints2, que nos sirve para obtener información sobre los dispositivos USB conectados, también registra las unidades mapeadas.

Además, también podemos obtener el listado de recursos compartidos accediendo a la clave:

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanServer\Shares.

Aplicaciones de inicio

Normalmente, las aplicaciones que se inician con el sistema pueden encontrarse en

© Universidad Internacional de La Rioja (UNIR)

varias ubicaciones:

- Carpeta de inicio general (ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp) y del usuario (Users\[USUARIO]\AppData\ Roaming\Microsoft\Windows\Start Menu\Programs\Startup).
- Registro de Windows general (SOFTWARE\Software\Microsoft\Windows\ CurrentVersion\Run) y de usuario (NTUSER.DAT).
- Servicios del Sistema Operativo.

Para analizar las aplicaciones que se inician con el equipo, lo más sencillo es utilizar herramientas de terceros como WhatInStartup, de Nirsoft, Autoruns, perteneciente a las SysInternals o *scripts* que automatizan esta tarea.

Otros elementos de interés dentro del Registro de Windows:

- **Zona horaria**
  - SYSTEM\ControlSet###\Control\TimeZoneInformation.
- **Último apagado**
  - SYSTEM\ControlSet###\Control\Windows (clave: ShutdownTime).
- **Barra de búsqueda**
  - NTUSER.DAT\Software\Microsoft\Windows\CurrentVersion\Explorer\WordWheelQuery\.
- **Impresoras**
  - SOFTWARE\Microsoft\Windows NT\CurrentVersion\Print\Printers\.

El registro de eventos

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El registro de eventos es en realidad un conjunto de archivos especiales donde se registran los eventos que se producen en el sistema.

En el registro de eventos podemos ver, por ejemplo, cuando un usuario inicia y cierra sesión, cuando se cambia la hora del sistema o cuando se conecta y desconecta un dispositivo.

A partir de Windows Vista, el registro de eventos está compuesto por un gran número de archivos con extensión EVTX ubicados en la ruta: Windows\System32\winevt\Logs\.

De todos los archivos que componen el registro de eventos —salvo que estemos buscando eventos de alguna herramienta en particular—, los archivos más relevantes, desde un punto de vista forense, son:

- Application.evtx.
- Security.evtx.
- System.evtx.

Los archivos de eventos almacenan, de cada evento, al menos la siguiente información:

- **Origen:** programa o componente del sistema que genera el evento.
- **Id. del evento:** número que identifica de manera única el evento.
- **Nivel del evento:** informativo, advertencia, error, crítico, etc.
- **Otros:** usuario, fecha y hora del evento, información varia sobre el sistema y texto asociado al evento.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Al igual que el registro de Windows, el registro de eventos es capaz de almacenar multitud de información relevante.

Para su análisis, suelen emplearse herramientas que nos permiten automatizar algunas tareas, realizar búsquedas y aplicar filtros. Las herramientas más comúnmente utilizadas suelen ser: Event Log Explorer y Logparser.

Aunque también es posible utilizar herramientas tipo SIEM (Security Information and Event Management) como ManageEngine Event Log Analyzer o LOGAlyze, entre otras.

Algunos de los eventos más típicos que podemos encontrarnos durante el análisis del registro de eventos son:

- **Inicios y cierres de sesión de los usuarios**
  - Archivo: Security.
  - EventID: 4624 (inicio) y 4634 (cierre).
- **Intentos incorrectos de *login***
  - Archivo: Security.
  - EventID: 4625.
- **Cambios en la fecha y la hora del equipo**
  - Archivo: Security.
  - EventID: 4616.
- **Ejecución de programas (no todos)**
  - Archivo: Application.

© Universidad Internacional de La Rioja (UNIR)

- EventID: múltiples.

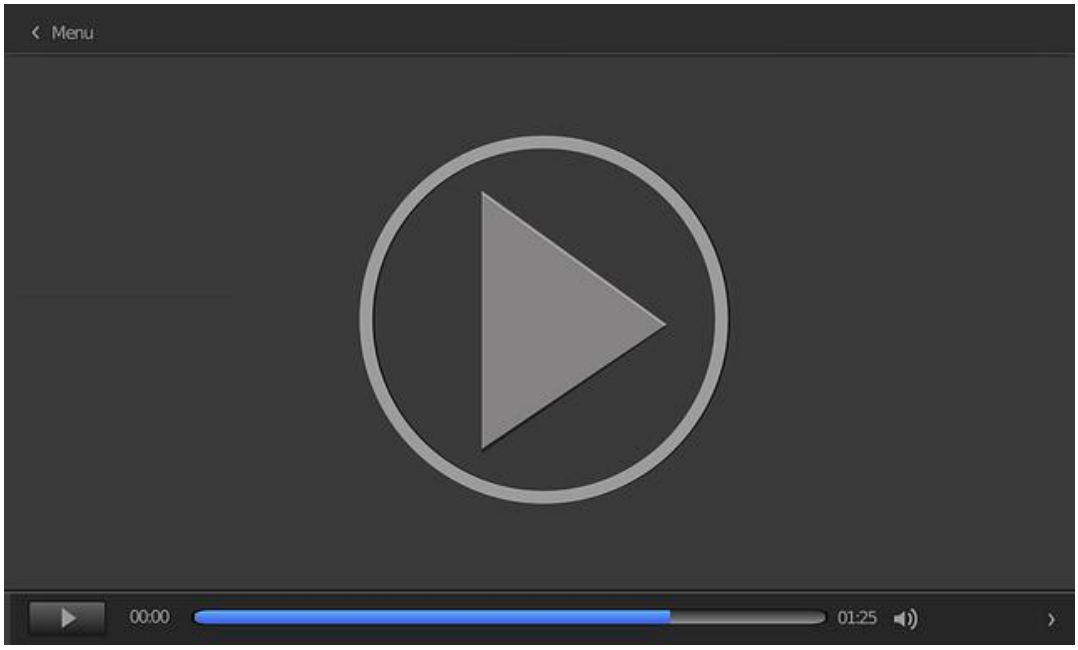
Analizando los eventos del archivo de eventos de aplicación, podemos ver registros de aplicaciones que se han ejecutado y de aplicaciones que han provocado algún error durante su ejecución.

Esto nos puede ayudar a ver en qué momento se ejecutaron determinadas aplicaciones y desde qué ruta fueron ejecutadas (por ejemplo, desde un dispositivo externo o desde una unidad de red).

Actividad reciente

Aunque utilizando Autopsy y el *plugin* específico podemos ver la actividad reciente del usuario, siempre es bueno conocer de dónde podemos obtener manualmente esa información.

En el siguiente vídeo, veremos el registro de Windows y el registro de eventos:



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=79053491-2060-

© Universidad Internacional de La Rioja (UNIR)

4020-8165-b0c900b6647b

Principalmente tenemos tres vías:

- Las UserAssist Keys.
- Las MRU Lists (Most Recently Used Lists).
- Archivos Prefetch.

Aunque como ya hemos visto, los eventos del sistema operativo también nos pueden dar información muy relevante al respecto.

UserAssist Keys

El Sistema Operativo Windows almacena una serie de entradas en el registro que nos permiten conocer qué programas se ejecutaron recientemente en un sistema.

Esto puede ser extremadamente valioso durante una investigación en la que queramos ver si se ejecutó una aplicación en particular, como una herramienta de cifrado o de borrado.

A diferencia de los archivos prefetch, los datos de UserAssist incluyen información sobre si una aplicación se ejecutó desde un enlace (archivo LNK) o directamente desde el ejecutable.

Las UserAssit Keys se almacenan en el registro de cada usuario en la ruta: NTUSER.DAT\ SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\UserAssist\. Dentro de esta clave veremos subclaves del tipo {F2A1CB5A-E3CC-4A2E-AF9D-505A7009D442}. Cada una de estas subclaves (GUID o Id. Único universal) representa un tipo específico (accesos directos, programas, etc.).

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Dentro de cada GUID tenemos una última subclave «Count» donde encontraremos la información del UserAssist (codificada en ROT-13) y algunos datos como el número de veces accedida.

Por supuesto, aunque podemos interpretar las UserAssit Keys de manera manual, siempre es más cómodo utilizar alguna herramienta como UserAssistView, de Nirsoft.

Most Recently Used List (MRU).

Las listas con las aplicaciones más recientemente accedidas las encontramos en el registro de Windows.

Podemos encontrarnos con varios tipos de MRU Lists:

- **Documentos recientes**
  - SFTWARE\Microsoft\Windows\CurrentVersion\Explorer\RecentDocs.
- **Run MRU (herramientas ejecutadas desde Inicio, Ejecutar)**
  - SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\RunMRU.
- **Typed URL (URLs introducidas en la barra de direcciones)**
  - Software\Microsoft\Internet Explorer\TypedURLs.

Además de las anteriores, también tenemos otras listas MRU de interés:

- Rutas utilizadas para guardar docs a través de «Guardar como…»
  - SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\ComDlg32\OpenSavePidlMRU.
- Lista de las herramientas utilizadas para abrir determinados tipos de archivo según su extensión.
  -

© Universidad Internacional de La Rioja (UNIR)

SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\FileExts.

Como siempre, la mejor manera de analizar estas listas de últimos archivos, programas o carpetas abiertas es utilizar herramientas que nos automaticen la extracción de la información; y Nirsoft nos proporciona tres de ellas: RecentFilesView, LastActivityView y OpenSaveFilesView.

Archivos Prefetch

Cuando un archivo se ejecuta de manera repetida Windows genera un archivo prefetch (.pf) que es algo así como un archivo pre-cargado, un archivo que agiliza la carga del archivo original. De esta forma, el Sistema Operativo se inicia con mayor velocidad y los programas que comúnmente utilizamos cargan más rápido.

Los archivos *prefetch* nacen con Windows XP, y se mantienen hasta el actual Windows. Pero, además de estos, con Windows Vista nacen los SuperFetch, que incrementa aún más el rendimiento ya que se crea una cache de ficheros a los que cada aplicación accede más frecuentemente.

Para saber si un equipo tiene habilitado el *prefetch,* debemos acceder a la entrada del registro: SYSTEM\ControlSet001\Control\Session Manager\Memory Management\PrefetchParameters.

Hay tenemos la clave «EnablePrefetcher», la cual tendrá un valor entre 0 y 3, lo cual indica:

- 0: deshabilitar Prefetch.
- 1: habilitar Prefetch de inicio de aplicaciones.
- 2: habilitar Prefetch de inicio del sistema.
- 3: habilitar Prefetch de inicio de aplicaciones y de inicio del sistema (valor por defecto).

© Universidad Internacional de La Rioja (UNIR)

Para saber si un equipo tiene habilitado Superfetch, en versiones anteriores de Windows teníamos una clave llamada «EnableSuperfetch», la cual toma valores entre 0 y 3 de igual forma que «EnablePrefetcher». Sin embargo, en las últimas versiones de Windows 10, tenemos que irnos al servicio SysMain, y ver si se encuentra activo, o no.

Los archivos Prefetch (.pf) se almacenan en la ruta «Windows\Prefetch» y, como en anteriores ocasiones, la mejor manera de analizarlos es utilizando *scripts* o herramientas de terceros como WinPrefetchView (Nirsoft) o Prefetch Viewer (PassMark Software).

Papelera de reciclaje

Cuando se elimina un archivo, este no se borra físicamente, sino que se envía a la papelera de reciclaje o se marca como borrado.

Esto nos permite a los forenses recuperar archivos eliminados utilizando herramientas específicas como **FTK Imager, Encase o Winhex** para recuperaciones sencillas y **Recuva, Photorec o R-Studio** para recuperaciones en bruto.

Cuando un archivo se envía a la papelera de reciclaje, el archivo no está borrado, tan solo se ha movido a una carpeta «especial» que tendremos que analizar.

La papelera de reciclaje en los Sistemas Operativos Windows modernos se encuentra en la raíz del dispositivo dentro de la carpeta «$Recycle.Bin». En esta carpeta se encuentran las papeleras de reciclaje de todos los usuarios que han iniciado sesión en el sistema.

Dentro de «$Recycle.Bin» tendremos una subcarpeta por cada uno de estos usuarios. Dicha subcarpeta se denomina con el SID del usuario (ej. S-1-5-21-…-…-…-1001).

En la papelera de reciclaje de cada usuario los archivos que veremos, tendrán

© Universidad Internacional de La Rioja (UNIR)

nombres aleatorios, del tipo 0NFFEM o 1CLQ7B. Estos nombres son completamente aleatorios, y no representan al archivo original, lo único que se mantiene del archivo original es la extensión.

Así, por ejemplo, si borramos el archivo «\Users\manuel\Desktop\paco.zip», en la papelera de reciclaje veremos dos archivos:

- $I[ALEATORIO].zip.
- $R[ALEATORIO].zip.

De los dos archivos que se generan en la papelera de reciclaje (ambos con el mismo valor aleatorio en el nombre), el archivo $R se corresponde con el archivo original eliminado ($R[ALEATORIO].zip = paco.zip) mientras que el archivo $I contiene la información del archivo eliminado, como el nombre y la ruta originales, la fecha de eliminación y su tamaño.

El análisis manual de los archivos de la papelera de reciclaje es relativamente sencillo. Sin embargo, también existen herramientas que nos facilitan la labor, y una de ellas es Rifiuti2.

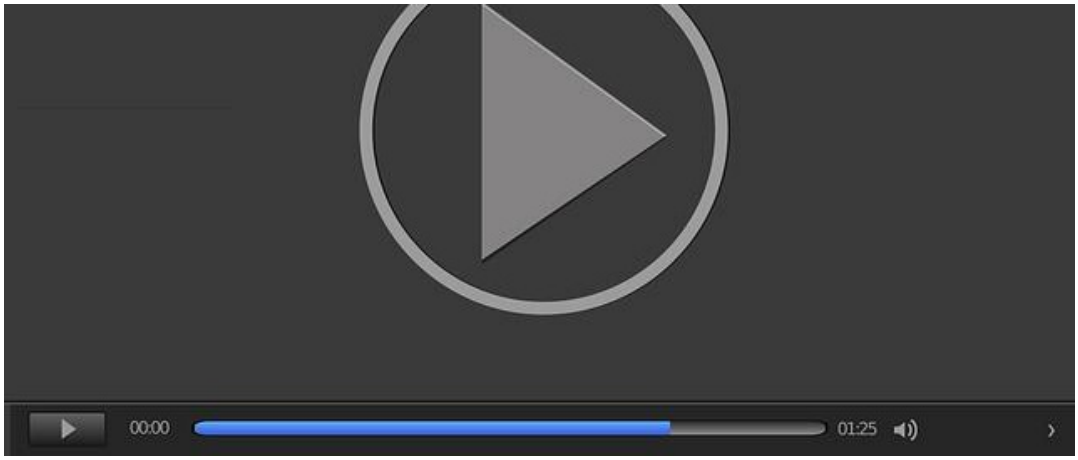
Para versiones de Windows anteriores a Windows Vista, la papelera de reciclaje se encuentra ubicado en «Recycler\{SID del usuario}», y los archivos que contienen la metainformación (los archivos $I[ALEATORIO]) son sustituidos por un único archivo llamado INFO2. Además, los archivos eliminados no comienzan con $R, aunque sí tienen nombres aleatorios.

En el siguiente vídeo, hablaremos sobre el análisis a bajo niveles de diversos dispositivos, a partir de la herramienta Active Disk Editor.



© Universidad Internacional de La Rioja (UNIR)

Ideas clave



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=6670eaba-4840-41b9-82dc-b19c00b9b819

© Universidad Internacional de La Rioja (UNIR)

7.3. Análisis de un S.O. Linux

El tipo de información que podemos recolectar y estudiar dentro de un Sistema Operativo Linux, al igual que en Windows es mucha y muy variada por lo que nos centraremos en:

- 1. Recolección de información volátil.
- 2. Los archivos de *log.*
- 3. Tareas programadas y servicios.

Recolección de la información volátil

Al igual que en los Sistemas Operativos Windows, los sistemas Linux manejan gran cantidad de información volátil, la cual se pierde al apagar el equipo. Por lo tanto, únicamente vamos a poder recolectar esta información si nos encontramos ante un equipo encendido.

Aunque vamos a ver distintos comandos para obtener información volátil dentro de un sistema Linux, debemos tener en cuenta que, dada la heterogeneidad de distribuciones, es posible que algunos de ellos no se denominen o no se ejecuten exactamente igual en todas ellas.

Aun así, se ha intentado trabajar únicamente sobre comandos genéricos y ampliamente disponibles.

Fecha y hora del sistema

Para obtener la fecha y hora de un sistema Linux, tan solo debemos ejecutar el comando *date.*

Este comando nos devuelve la fecha y hora local del sistema o, si le pasamos el

© Universidad Internacional de La Rioja (UNIR)

parámetro «--utc», la fecha en UTC+0.

Además, también podemos ejecutar el comando «hwclock» para leer el reloj hardware del equipo. Ejecutando el comando «hwclock --show –utc», obtendremos la fecha en formato UTC+0. Además, podemos utilizar la opción «--verbose» para obtener información sobre el reloj *hardware.*

Usuarios del equipo

Para obtener el listado de usuarios de un equipo Linux, lo más sencillo es listar el contenido del archivo «/etc/passwd». Este archivo contiene una entrada por cada uno de los usuarios del equipo, y en él se almacenan, entre otras cosas, las credenciales de cada uno de estos usuarios, su directorio home y la Shell (consola de comandos) que utilizan.

Para listar el contenido del archivo tan solo tenemos que ejecutar el comando: «cat /etc/passwd».

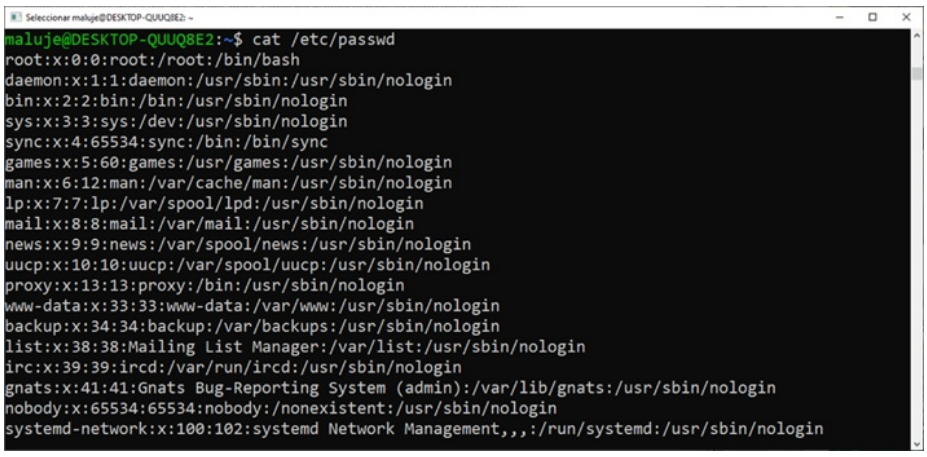


Figura 6. Contenido del archivo /etc/passwd. Fuente: elaboración propia.

La estructura que sigue cada una de las entradas de este archivo es la siguiente:

© Universidad Internacional de La Rioja (UNIR)

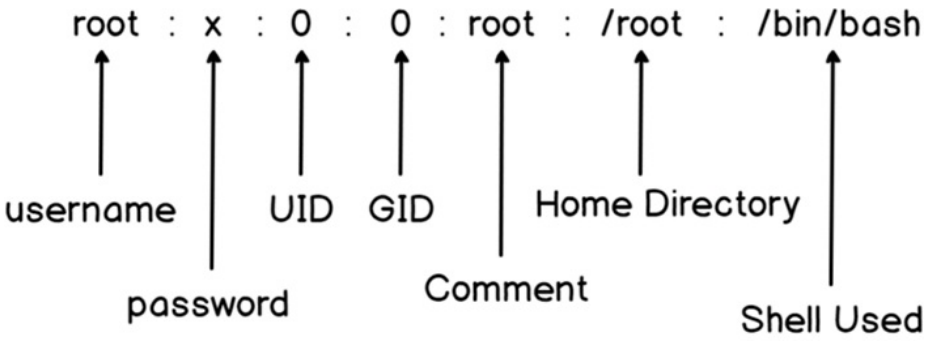


Figura 7. Estructura de las entradas del archivo /etc/passwd. Fuente: https://www.cnblogs.com/mouseleo/p/13307017.html.

Que en la columna *password* tengamos una «x» quiere decir que la contraseña está encriptada, y que se almacena en el archivo «/etc/shadow», de acceso restringido.

Usuarios que han iniciado sesión

Para ver los usuarios que han iniciado sesión en un equipo Linux, tenemos dos opciones, en función de si el equipo se encuentra encendido o apagado. Si nos encontramos con el equipo encendido y tenemos acceso a la consola, podemos utilizar el **comando «last».**

Por el contrario, si nos encontramos con el equipo apagado, todavía podemos obtener la misma información analizando los archivos «/var/log/wtmp» y «/var/log/btmp» que almacenan los históricos de inicio de sesión y los fallos en los inicios de sesión respectivamente. El problema de estos archivos es que son logs en binario, por lo que, aunque podemos leerlos con un simple «cat», tendremos que interpretar los resultados.

Historial de comandos ejecutados

Para ver los comandos ejecutados en el terminal, tenemos también dos opciones, en

© Universidad Internacional de La Rioja (UNIR)

función de si el equipo se encuentra encendido o apagado.

Si nos encontramos con el equipo encendido y tenemos acceso a la consola, podemos utilizar el comando «history».

Por el contrario, si nos encontramos con el equipo apagado, todavía podemos obtener la misma información analizando los archivos «.bash_history» dentro de la «home» de cada uno de los usuarios y el archivo «.bash_history» raíz, ubicado en la carpeta «/root/».

Archivo.bash_logout

El archivo «.bash_logout», ubicado en la «home» del usuario, contiene los comandos que se ejecutarán cuando el usuario cierre la sesión abierta en el terminal.

Si nos encontramos con una máquina encendida y comprometida, este archivo puede aportar información sobre cómo el delincuente oculta sus huellas. En la siguiente imagen podemos observar un sencillo ejemplo.

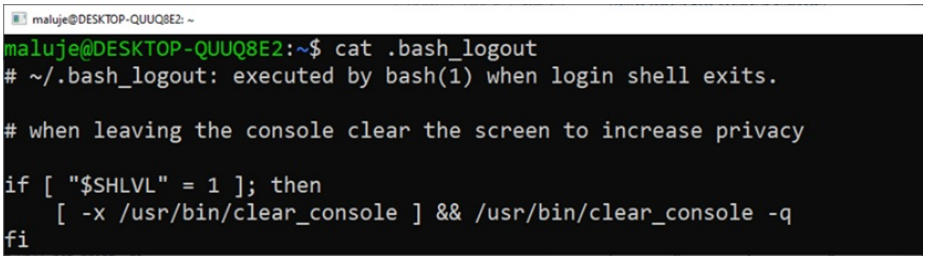


Figura 8. Ejemplo del archivo.bash_logout. Fuente: elaboración propia.

Archivos abiertos

Como ya hemos mencionado, conocer los archivos abiertos por los usuarios que han iniciado sesión en el equipo puede aportar pistas muy importantes de cara a la investigación.

En Linux, para poder ver la lista de archivos abiertos, podemos utilizar el comando

© Universidad Internacional de La Rioja (UNIR)

«lsof» (List Open Files). Este comando nos ayudará a encontrar todos los archivos abiertos asociados a puertos, servicios y procesos.

El comando «lsof» nos muestra distinta información sobre los archivos abiertos, entre otras cosas:

- El comando asociado al proceso que ha abierto el archivo.
- El PID del proceso y el usuario que lo ha lanzado.
- El descriptor del archivo (columna FD), que nos indica si son datos, directorios, librerías compartidas, etc.
- El nombre con la ruta completa del archivo.
- Información de red.

Cuando se está investigando un incidente, las trazas de las comunicaciones de red suelen ser una gran fuente de información. Sobre todo, en casos relacionados con infecciones por *malware,* fugas de información o incidentes de seguridad.

En estos casos, cuanta más información tengamos sobre la arquitectura de la red y sobre las comunicaciones establecidas (y quién las ha establecido), mucho mejor.

Información de red: información general

Antes de comenzar a obtener información sobre las conexiones establecidas, es necesario obtener la propia configuración de los interfaces de red del equipo.

Para ello, podemos utilizar las propias herramientas del sistema, como el comando «ifconfig» (similar a «ipconfig» en Windows), que nos muestra información sobre la configuración de los distintos interfaces de red del equipo.

Información de red: conexiones abiertas

© Universidad Internacional de La Rioja (UNIR)

Cuando estamos analizando un equipo que sospechamos se encuentra infectado con un *malware,* uno de los primeros puntos a analizar es el de las conexiones abiertas. Las conexiones que dicho equipo tiene establecidas con otros sistemas (ejemplo, conexiones con el centro de control del *malware* o conexiones con el sistema de *keylogger* remoto).

Para ello podemos utilizar el comando «lsof», utilizado para listar los archivos abiertos, pero con parámetros específicos que nos permiten obtener solo la información que nos interesa.

- Para listar las conexiones TCP: «lsof -i TCP»
- Para listar las conexiones UDP: «lsof –i UDP»
- Para listar conexiones a la escucha: «lsof -iTCP –sTCP:LISTEN» o «lsof -iUDP –sUDP:LISTEN»
- Para listar procesos en escuchando o transmitiendo por un determinado puerto (ejemplo, 80): «lsof -i:80»
- Para listar procesos utilizando un determinado protocolo de comunicaciones o servicio (ejemplo, http): «lsof –i:http».

Procesos en ejecución

Los procesos que se encuentran en ejecución y la manera en que estos han sido «lanzados» es también importante de cara a una investigación.

Analizando los procesos en ejecución podemos saber, por ejemplo, si se están utilizando los recursos de la empresa para minar criptomonedas o si algún equipo está infectado con un software malicioso.

Como hemos comentado antes, la manera más sencilla de ver los procesos en

© Universidad Internacional de La Rioja (UNIR)

ejecución es a través de los comandos que nos proporciona el propio Sistema Operativos como «ps» o «pstree» y el comando «top», que nos permite ver el estado actual de la máquina, sus procesos y los usuarios que los han lanzado.

Procesos en ejecución: ps y pstree

Los comandos del sistema «ps» y «pstree» nos muestran el listado de procesos en ejecución. La diferencia es que «pstree» nos muestra la información en forma de árbol, lo que nos permite ver quién ha lanzado qué proceso.

Otra pequeña diferencia es que «pstree» muestra los hilos asociados a cada proceso de manera predeterminada, mientras que para ver los hilos de ejecución de cada proceso con el comando «ps» debemos ejecutar «ps –eLf», ya que, si no, parecerá que ambos comandos dan información diferente.

El comando «ps» tiene múltiples parámetros para visualizar los procesos en ejecución, aunque la manera más utilizada de ejecutarlo es «ps aux».

- a: eliminar la restricción BSD «only yourself» para agregar procesos de otros usuarios.
- u: utilizar el formato orientado al usuario.
- x: eliminar la restricción BSD «must have a tty» para agregar procesos que no tengan una tty (terminal) asociada.

Procesos en ejecución: *kill*

Si nos encontramos en un equipo de respuesta a incidentes o estamos actuando como tal en nuestra organización, es posible que debamos «matar» algún proceso malicioso que detectemos.

Quizás un *malware* que está cifrando la información, quizás una herramienta de minado de criptomonedas, en ocasiones, vamos a necesitar finalizar procesos que

© Universidad Internacional de La Rioja (UNIR)

no deberían estar funcionando y, para eso, utilizaremos el comando «kill».

Podemos matar procesos simplemente con «kill [PID]» (ejemplo, «kill 1709» para matar el proceso con PID = 1709), lo que enviará al proceso una señal del tipo SIGTERM (finalizar proceso).

Es posible que esto no siempre ocurra (incluso, es probable que no nos interese enviar esa señal a un *malware),* por lo que podemos especificar qué señal enviar al proceso para su finalización, es la más normal SIGKILL (código 9), la cual fuerza la finalización del proceso independientemente de su estado (ejemplo, «kill -9 1709» o «kill –SIGKILL 1709»).

Podemos ver el listado de señales que podemos enviar a los procesos con el comando «kill –l».

Procesos en ejecución: volcado de procesos

El directorio «/proc» de un sistema Linux es un directorio especial. No existe realmente (solo podemos adquirirlo en caliente), pero contiene información muy relevante.

Este directorio especial contiene todos los detalles de un sistema Linux, incluyendo su kernel, los procesos en ejecución y los parámetros de configuración del sistema.

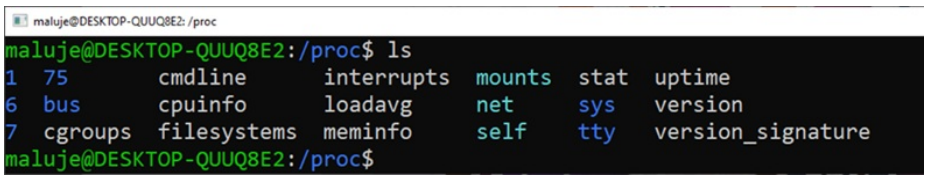


Figura 9. Contenido de la carpeta /proc. Fuente: elaboración propia.

Si quisiéramos adquirir la información del proceso con PID 6, tan solo tendríamos que acceder a la carpeta «/proc/6/» donde encontraríamos una serie de subcarpetas

© Universidad Internacional de La Rioja (UNIR)

y archivos con distinta información sobre el proceso.

Algunos de los archivos de interés que podemos encontrar son:

- cmdline: comando ejecutado y sus parámetros.
- cwd: enlace simbólico al directorio del trabajo del proceso.
- environ: variables de entorno del proceso.
- fd: contiene los descriptores de archive del proceso. Podemos ver qué archivos o dispositivos está utilizando.
- maps, statm, y mem: espacio de memoria en uso por el proceso.
- stat and status: nos proporciona información sobre el estado del proceso.

Un archivo que suele ser interesante dentro del directorio «/proc» es el archivo «/proc/cmdline», el cual nos muestra los parámetros pasados al kernel durante el arranque (ejemplo, Malware ejecutándose en el arranque).

Por su parte, en «/proc/mounts», también podemos encontrar información interesante, ya que nos muestra todos los puntos de montaje en uso. Como es un directorio bastante complejo y lleno de información de interés, la recomendación es que siempre que os encontréis una máquina Linux encendida le echéis un vistazo y adquiráis toda la información que pudiera ser de interés.

Últimos archivos modificados

Analizando las fechas de modificación, acceso y creación de los archivos, podemos intentar reproducir las acciones realizadas por los atacantes en un sistema. Para ello podemos utilizar el comando «find». Este comando nos permite especificar qué queremos buscar exactamente (archivos, carpetas, etc.) así como la información que queremos obtener.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Gracias al comando «find» podemos crear una línea temporal de las acciones que se han ido realizando sobre un sistema. Eso sí, debemos tener en cuenta que todas las fechas son susceptibles de ser alteradas, por lo que tenemos que prestar especial atención a cualquier incoherencia que podamos encontrar.

Para obtener el listado de los últimos archivos modificados tan solo debemos ejecutar el comando:

- find. -type f -user root -perm +111 –printf \ %TY%Tm%Td%TH%TM%TS %h/%f\n| sort –nr
- -type f Archivo.
- -user root Usuario (podemos no indicarlo).
- - perm +111 Permisos (ejecutable por cualquiera).
- - printf … Qué queremos ver (fecha y datos del archivo).
- | sort –nr Ordenamos por fecha de más reciente a menos (realmente se ordena de manera numérica descendientemente).

Últimos archivos creados

Por supuesto, también podemos utilizar el comando «find» para obtener la lista de los archivos creados recientemente. Para ello, ejecutaremos el mismo comando que para listar los archivos modificados, pero indicando que la fecha que queremos obtener es la de creación:

- find. -type f -perm +111 -printf %CY%Cm%Cd%CH%CM%CS \ %h/ %f\n | sort -nr | head -30.

El parámetro «| head -30» es para limitar el número de archivos a mostrar.

Archivos de *log*

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Los archivos de *log* de Linux (al igual que en cualquier otro SO) almacenan información sobre las actividades realizadas en el sistema. Los podríamos asimilar a los archivos de eventos que vimos para sistemas Windows.

La mayoría de los registros de Linux se almacenan en la ruta «/var/log/», y suelen ser archivos de texto plano.

Aunque hay muchos y variados archivos de *log,* en esta sesión nos vamos a centrar en aquellos que tienen mayor interés desde un punto de vista forense.

Cuando trabajamos con archivos de *log,* es recomendable tener una idea de qué es lo que buscamos, ya que, aunque es posible una revisión en profundidad de todos los archivos de *log,* la cantidad de tiempo y recursos que invertiríamos harían inviable la pericial.

Es por ello por lo que en los análisis forenses es recomendable centrarse en:

- /var/log/auth.log (o /var/log/secure).
- /var/log/daemon.log.
- /var/log/syslog (o /var/log/messages).
- Otros archivos de log específicos de algunas aplicaciones que fueran de interés (ej. Mysql, apache, etc.).
- /var/log/auth.log (o /var/log/secure).

El **archivo de *log* «auth.log»** contiene los eventos de autenticación y de inicios y cierres de sesión (incluidos los cron o demonios). Registra todo lo relacionado con los procedimientos que implican la autorización del usuario.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

El análisis del archivo «auth.log» puede aportarnos información sobre intentos de inicio de sesión fallidos, ataques por fuerza bruta o intentos de explotación de vulnerabilidades relacionadas con el mecanismo de autorización.

/var/log/daemon.log

Registra los eventos generados por los demonios en segundo plano. Por lo general, los procesos y/o servicios en segundo plano mantienen *logs* de gran valor relacionados con las actividades de un usuario.

También debemos tener en cuenta que algunos programas (por ejemplo, MySQL) registran los *logs* de sus servicios en segundo plano en archivos específicos.

/var/log/syslog (o /var/log/messages)

Contiene mensajes generales del sistema. Se utiliza, principalmente, para registrar información y mensajes no críticos lanzados por el sistema.

Podemos obtener información sobre errores durante el inicio del sistema o errores relacionados con las aplicaciones, por lo que suele ser un buen punto de partida cuando algo no funciona correctamente.

En este archivo podemos ver también los parámetros con los que se ejecutan determinados demonios.

Otros archivos de *log*

Como ya hemos mencionado, muchas aplicaciones almacenan información en sus propios archivos de log (ejemplo, Mysql, apache, etc). Estos otros archivos de *log* pueden ser de interés si estamos realizando un análisis forense sobre algo relacionado con ellos.

© Universidad Internacional de La Rioja (UNIR)

Por ejemplo, real: el servidor web de una consultoría fue hackeado, y robaron cientos de credenciales y datos de clientes. En este caso hubo que analizar los *logs* de apache (habían aprovechado una vulnerabilidad), httpd y mysql para obtener toda la información sobre lo que los atacantes habían podido hacer en el sistema.

Tareas programadas y servicios

Para programar tareas en sistemas Linux, solemos utilizar «cron». Esta herramienta permite a los usuarios de Linux ejecutar automáticamente comandos o *scripts* a una hora o fecha específicas.

Se utiliza normalmente para tareas administrativas, pero puede ser usado para ejecutar cualquier cosa, como *malware* persistente.

Hay, al menos, dos maneras distintas de utilizar cron para programar tareas:

- Utilizando «crontab».
- Añadiendo el script al directorio «/etc/cron.[PERIODICIDAD]».

Tareas programadas: crontab

Una de las maneras más comunes para programar tareas es utilizar «crontab». Mediante «crontab» podemos configurar un «cron» e indicar el momento en que ejecuta, el comando o *script* y el usuario que lo ejecutará (debe tener privilegios).

Por un lado, los ficheros crontab —en los que podemos ver los «cro» configurados para cada usuario— se guardan en: /var/spool/cron/crontabs/[USUARIO]. También podemos encontrar archivos crontab en el directorio «/etc/cron.d».

Por otro lado, tenemos también un archivo crontab general que podemos encontrar en: «/etc/crontab». Este crontab general es el que «lanza» los *scripts* ubicados en los

© Universidad Internacional de La Rioja (UNIR)

directorios del tipo «/etc/cron.[PERIODICIDAD]» que veremos más adelante.

Los archivos «crontab» tienen la siguiente estructura:



Figura 10. Estructura de los archivos crontad.

Analizando un archivo «crontab» podemos ver algo así: 10 * * * * perl /var/tmp/xxcrFWrZMH >/dev/null 2>&1.

Como vemos, el cron anterior se ejecuta todas las horas a los 10 minutos, y lanza un *script* en *perl* de nombre sospechoso (xxcrFWrZMH). Probablemente, un *malware.*

La salida del *script* la redirige a /dev/null para que no quede registrada en ningún sitio.

Tareas programadas: /etc/cron.[PERIODICIDAD]

La segunda manera de usar «cron» consiste en añadir el script a alguno de los directorios del tipo «cron.[PERIODICIDAD]» ubicados en «/etc/». Estos directorios suelen ser: cron.hourly, cron.daily, cron.weekly y cron.monthly.

Cualquier *script* que copiemos en los directorios indicados se ejecutará con la periodicidad de dicho directorio (cada hora, cada día, cada semana o cada mes en el

© Universidad Internacional de La Rioja (UNIR)

ejemplo anterior).

Los *scripts* de estos directorios comienzan por «#!/bin/sh», lo que indica que se trata de un *script* Shell de *bash.* El resto del contenido es el código del propio *script.*

© Universidad Internacional de La Rioja (UNIR)

7.4. Análisis de un S. O. MacOS

El tipo de información que podemos recolectar y estudiar dentro de un Sistema Operativo MacOS, aunque en algunos casos sea similar a la que podemos encontrar en sistemas Linux, tiene una serie de peculiaridades que es necesario conocer.

Similitudes con sistemas Linux

Aunque Linux y MacOS no son «parientes» directos, sí que comparten una gran parte de su estructura y manera de funcionar. Por ejemplo, en MacOS tenemos los directorios «/etc», «/var» y «/home» al igual que en Linux. Sin embargo, su contenido no siempre coincide.

La manera en que se asignan permisos a los archivos y usuarios también es similar en Linux y MacOS, y veremos que muchos de los comandos que vimos para Sistemas Operativos Linux funcionan para sistemas MacOS.

Recolección de información volátil

Como ya vimos para Windows y Linux, los sistemas MacOS también manejan gran cantidad de información volátil, la cual se pierde al apagar el equipo. Por lo tanto, únicamente vamos a poder recolectar esta información si nos encontramos ante un equipo encendido.

Aunque vamos a ver distintos comandos para obtener información volátil dentro de un sistema MacOS, debemos tener en cuenta que, futuras actualizaciones y/o configuraciones de los sistemas pueden hacer que algunos comandos no se ejecuten exactamente igual en todas ellas.

Aun así, se ha intentado trabajar solo sobre comandos genéricos y ampliamente disponibles.

© Universidad Internacional de La Rioja (UNIR)

Fecha y hora del sistema

Para obtener la fecha y hora de un sistema Linux, tan solo debemos ejecutar el comando «date». Este comando nos devuelve la fecha y hora local del sistema o, si le pasamos el parámetro «-u», la fecha en UTC+0.

Usuarios del equipo

Para obtener el listado de usuarios de un equipo MacOS, lo más sencillo es listar el contenido del archivo «/etc/passwd». Tal y como haríamos en un Sistema Linux.

Este archivo contiene una entrada por cada uno de los usuarios del equipo y en él se almacenan, entre otras cosas, las credenciales de cada uno de estos usuarios, su directorio *home* y la Shell (consola de comandos) que utilizan.

Para listar el contenido del archivo, tan solo tenemos que ejecutar el comando: «cat /etc/passwd».

El contenido de este archivo tiene la misma estructura que en un Sistema Operativo Linux. Sin embargo, al contrario que Linux, en los Sistemas Operativos MacOS, cuando la contraseña de los usuarios está cifrada, no se almacena en «/etc/shadow».

En MacOS hay un archivo «shadow» por cada usuario, y se encuentran en la ruta «/var/db/dslocal/nodes/Default/users/» en archivos.Plist. Estos archivos contienen información sobre la contraseña y su creación en un archivo de tipo diccionario.

Usuarios que han iniciado sesión

Para ver los usuarios que han iniciado sesión en un equipo Linux, tenemos dos opciones, en función de si el equipo se encuentra encendido o apagado. Si nos encontramos con el equipo encendido, y tenemos acceso a la consola, podemos utilizar el comando «last».

© Universidad Internacional de La Rioja (UNIR)

Por el contrario, si nos encontramos con el equipo apagado todavía podemos obtener la misma información analizando el archivo «/var/run/utmpx» que almacena el histórico de inicios de sesión.

El problema de este archivo (como también ocurría en Linux) es que es un *log* en binario, por lo que, aunque podemos leerlos con un simple «cat», tendremos que interpretar los resultados.

Historial de comandos ejecutados

Para ver los comandos ejecutados en el terminal también tenemos dos opciones (al igual que en Linux):

Si nos encontramos con el equipo encendido y tenemos acceso a la consola, podemos utilizar el comando «history»

Por el contrario, si nos encontramos con el equipo apagado, todavía podemos obtener la misma información analizando los archivos «.bash_history» (o «.zsh_history», según el terminal que tenga configurado el usuario) dentro de la “

home de cada uno de los usuarios.

Debemos tener en cuenta que podemos encontrar información de este tipo en varios archivos «.[TERMINAL]_history». Por ejemplo, un usuario puede haber ejecutado unos comandos en un terminal «bash», los cuales se encontrarán registrados en «.bash_history» y otros distintos en un terminal «zsh», los cuales podremos ver en el archivo «.zsh_history».

Archivos abiertos

Como ya hemos mencionado, conocer los archivos abiertos por los usuarios que han iniciado sesión en el equipo puede aportar pistas muy importantes de cara a la investigación.

© Universidad Internacional de La Rioja (UNIR)

En MacOS (como también podemos hacer en Linux), para poder ver la lista de archivos abiertos podemos utilizar el comando «lsof» (List Open Files).

Este comando nos ayudará a encontrar todos los archivos abiertos asociados a puertos, servicios y procesos.

Procesos en ejecución

Recordemos que la manera más sencilla de ver los procesos en ejecución es a través de los comandos que nos proporciona el propio Sistema Operativo como «ps» o el comando «top».

El comando top nos permite ver el estado actual de la máquina, sus procesos y los usuarios que los han lanzado. Por su parte, el comando «ps» nos muestra el listado de procesos en ejecución. Este comando «ps» tiene múltiples parámetros para visualizar los procesos en ejecución, aunque la manera más utilizada de ejecutarlo es «ps aux».

Procesos en ejecución: *kill*

Si nos encontramos en un equipo de respuesta a incidentes o estamos actuando como tal en nuestra organización, es posible que debamos "matar" algún proceso malicioso que detectemos.

Quizá un malware que está cifrando la información, quizá una herramienta de minado de criptomonedas, en ocasiones, vamos a necesitar finalizar procesos que no deberían estar funcionando y para eso utilizaremos el comando "kill".

Podemos matar procesos simplemente con "kill [PID]" (ej. "kill 1709" para matar el proceso con PID = 1709), lo que enviará al proceso una señal para que finalice su ejecución.

© Universidad Internacional de La Rioja (UNIR)

Es posible que esto no siempre ocurra (incluso es probable que no nos interese enviar esa señal a un malware), por lo que podemos especificar qué señal enviar al proceso para su finalización, siendo la mas normal KILL (código 9), la cual fuerza la finalización del proceso independientemente de su estado (ej. “kill -9 1709” o “kill –KILL 1709”).

Podemos ver el listado de señales que podemos enviar a los procesos con el comando “kill –l” (tened en cuenta que no se nombran de la misma manera que en Linux).

Procesos en ejecución: Volcado de procesos

En Linux el directorio “/proc” contiene todos los detalles del sistema, incluyendo su kernel, los procesos en ejecución y los parámetros de configuración del sistema.

Sin embargo, en MacOS no existe este directorio y la obtención de la información sobre los procesos no puede realizarse de la misma manera que cuando analizamos un sistema Linux.

La alternativa “sencilla” para obtener información relacionada con los procesos en ejecución en un MacOS sería utilizar el “Monitor de Actividad”.

Desde el “Monitor de actividad” y haciendo doble clic sobre el proceso concreto a analizar, podemos obtener información y estadísticas.

Incluido el proceso padre (quién lo ha lanzado), el usuario asociado y los archivos y puertos abiertos.

Además, tenemos la opción de “Muestrear” el proceso, lo que creará un detallado informe sobre el mismo en el que se incluye información relevante para poder realizar un análisis sobre su comportamiento.

No vamos a obtener lo mismo que con un volcado, pero al menos sí vamos a poder

© Universidad Internacional de La Rioja (UNIR)

estudiar su comportamiento.

Últimos archivos modificados

Analizando las fechas de modificación, acceso y creación de los archivos, podemos intentar reproducir las acciones realizadas por los atacantes en un sistema.

Para ello podemos utilizar el comando "find". Este comando nos permite especificar qué queremos buscar exactamente (archivos, carpetas, etc.) así como la información que queremos obtener.

Gracias al comando "find" podemos crear una línea temporal de las acciones que se han ido realizando sobre un sistema. Eso sí, debemos tener en cuenta que todas las fechas son susceptibles de ser alteradas, por lo que tenemos que prestar especial atención a cualquier incoherencia que podamos encontrar.

Para obtener el listado de los últimos archivos modificados tan solo debemos ejecutar el comando:

find. –type f –user root –perm +111 -newermt 'YYYY-MM-DD HH:MM'

. Directorio actual

-type f Archivo

-user root Usuario propietario

-perm +111 Permisos (ejecutable por cualquiera)

-newermt Última modificación desde…

Últimos archivos creados

Por supuesto, también podemos utilizar el comando "find" para obtener la lista de los archivos creados recientemente.

© Universidad Internacional de La Rioja (UNIR)

Para ello ejecutaremos el mismo comando que para listar los archivos modificados, pero indicando que la fecha que queremos obtener es la de creación:

find. –type f –user root –perm +111 -newerBt 'YYYY-MM-DD HH:MM'

newerBT Creados a partir de…

Los archivos de log

De manera similar a cuando estudiamos los archivos de log de Linux (y en realidad los de cualquier SO), estos archivos almacenan información sobre las actividades realizadas en el sistema. Los podríamos asimilar a los archivos de eventos que vimos para sistemas Windows.

La mayoría de los archivos de log de MacOS se almacenan en las rutas:

•/var/log/ Logs del Sistema

•/Library/Logs/ Logs de las aplicaciones del Sistema

•/Users/[USUARIO]/Library/Logs Logs de las aplicaciones de usuario

Aunque hay distintos archivos de log, en esta sesión nos vamos a centrar en aquellos que tienen mayor interés desde un punto de vista forense.

Cuando trabajamos con archivos de log, es recomendable tener una idea de qué es lo que buscamos ya que, aunque es posible una revisión en profundidad de todos los archivos, la cantidad de tiempo y recursos que invertiríamos harían inviable la pericial.

Es por ello por lo que en los análisis forenses es recomendable centrarse en:

•/var/log/system.log

© Universidad Internacional de La Rioja (UNIR)

•/var/log/install.log

•Otros archivos de log específicos de aquellas aplicaciones que fueran de interés para la pericial (ej. Mysql, apache, etc.)

Los archivos PList

Los archivos Plist (Property list) almacenan información en forma de clave–valor en formato binario (BPlist) o XML (Plist).

El uso más común de estos archivos es almacenar las preferencias del usuario, pero también podemos encontrar información relevante como *tokens* de inicio de sesión, contraseñas o metadatos (ejemplo, información sobre las partes de una grabación de audio).

También podemos encontrar información sobre el sistema operativo. Por ejemplo, el archivo «/System/Library/CoreServices/SystemVersion.plist», nos proporciona información sobre la versión concreta del Sistema Operativo instalado en el equipo.

Los archivos Plist tienen como extensión «.plist», por lo que es muy sencillo localizarlos mediante una búsqueda en caliente (con el equipo encendido) o en frío (con el equipo apagado).

Para visualizar estos archivos, podemos utilizar cualquier editor de texto plano (en el caso de Plist en formato XML) o herramientas específicas como: Plist Explorer, PlistEdit Pro o Plist Pad, entre otras.

Una ruta muy interesante para analizar archivos Plist es la carpeta de preferencias de los usuarios ubicada en la ruta: $HOME/Library/Preferences/.

En esta carpeta encontraremos la mayoría de los archivos Plist de configuración de los programas que el usuario ha ejecutado en el equipo. También podemos encontrar múltiples archivos Plist en la carpeta de preferencias global, ubicada en la ruta: /Library/Preferences/.

© Universidad Internacional de La Rioja (UNIR)



Figura 11. Extracto del archivo «org.videolan.vlc.plist». Fuente: elaboración propia.

LaunchAgents y daemons en MacOS

Hay dos tipos de archivos en MacOS que gestionan los procesos del sistema: los **LaunchAgents** y los **daemons** (demonios).

Los LaunchAgents dependen de un usuario, por lo que es necesario iniciar sesión para que se ejecuten. Estos procesos se ejecutan en segundo plano, y son capaces de interactuar con el interfaz del sistema.

Por su parte, los *daemons* no tienen interfaz y no dependen de un usuario, sino que se inician con el propio sistema.

Su definición, tanto de los LaunchAgents como de los daemons se realiza a través de archivos Plist.

Los archivos Plist que almacenan los parámetros de ejecución de los LaunchAgents y los Daemons los podemos encontrar en tres ubicaciones distintas del sistema:

- «/System/Library/» Elementos del sistema
- LaunchAgents/ y LaunchDaemons

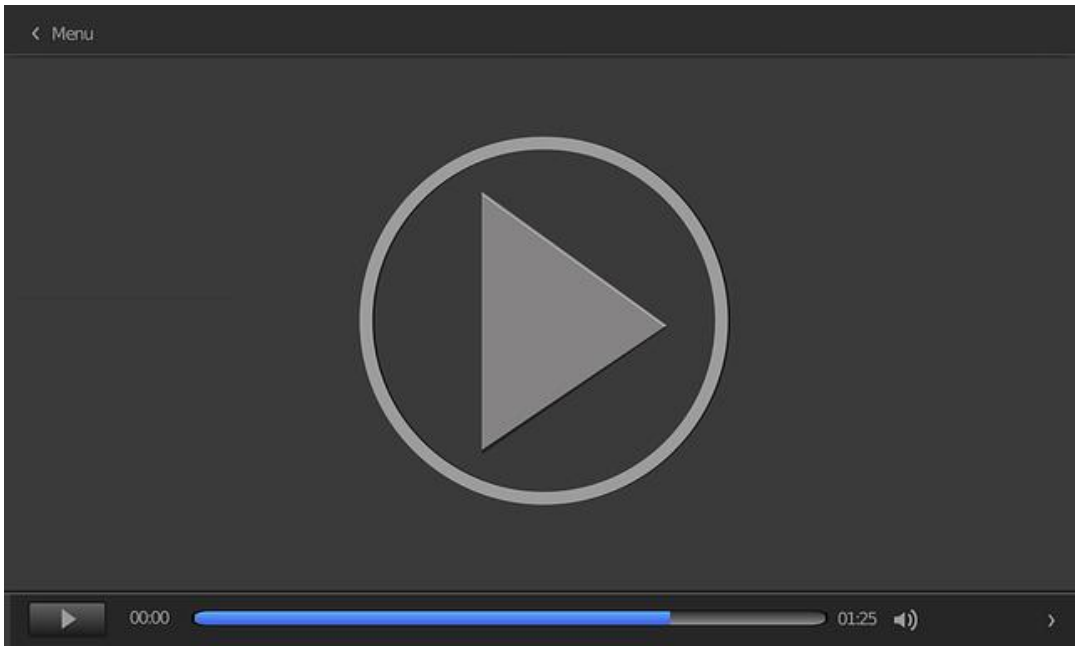
© Universidad Internacional de La Rioja (UNIR)

- «/Library/» Elementos comunes a todos los usuarios
  - LaunchAgents/ y LaunchDaemons.
- «$HOME/Library/» Elementos propios de cada usuario
  - LaunchAgents.

Por seguridad, la carpeta «/System/Library/» está protegida, y solo el propio sistema tiene acceso a ella, por lo que no deberíamos encontrar en ella (en principio) elementos externos.

Si durante un análisis forense encontramos algo extraño en esta carpeta, debemos prestar especial atención, ya que probablemente se trate de un *malware* o algún otro programa no legítimo.

En el siguiente vídeo hablaremos sobre Uso de las herramientas Passware Encryption Analyzer y Passware Kit Forensics para la localización de archivos cifrados y la ruptura de contraseñas:

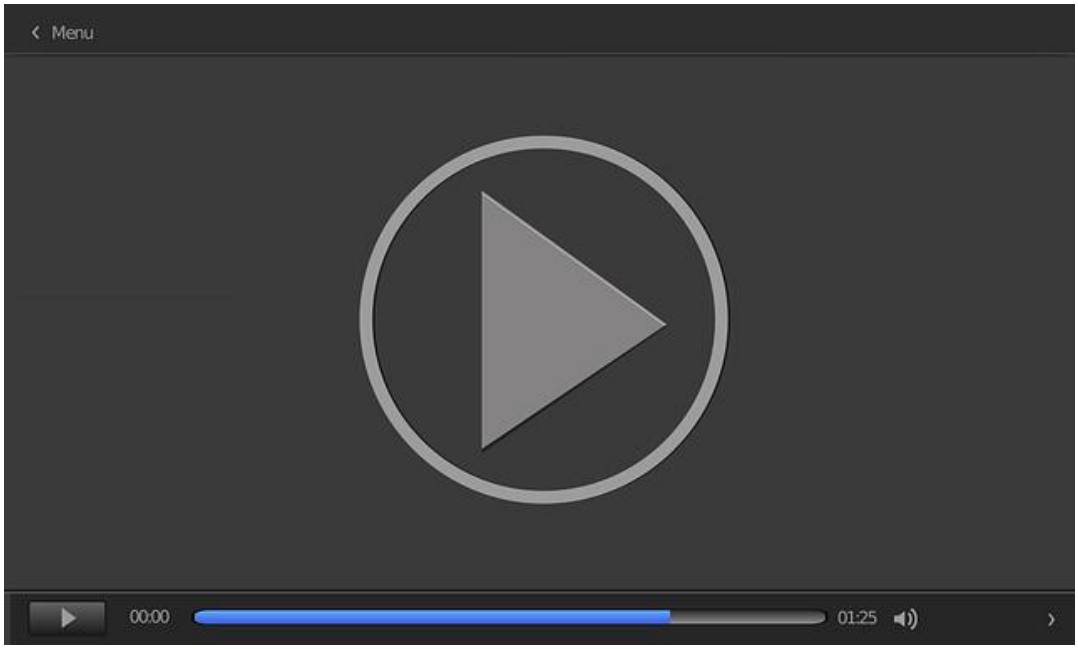


© Universidad Internacional de La Rioja (UNIR)

Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=701b6148-b031-4377-aadd-b19c00b54a39

En el siguiente vídeo, veremos cómo analizar los metadatos a nivel forense:



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=ee7206ea-361e-46af-aff6-b0c900b6bcb2

© Universidad Internacional de La Rioja (UNIR)

7.5. Referencias bibliográficas

Carvey, H. (2018). *Investigating Windows Systems.* Academic Press.

Grundy, B.J. (2020). The Law Enforcement and Forensic Examiner's Introduction to Linux. https://linuxleo.com/Docs/LinuxLeo_4.94.pdf.

Bhavana Maddu, P.V.R.D Prasad Rao (2020). OS X Artifact Analysis. https://www.ijrte.org/wp-content/uploads/papers/v7i6s/F02090376S19.pdf.

© Universidad Internacional de La Rioja (UNIR)

Windows Forensic Analysis Poster

SANS Institute. (2021). Windows Forensic Analysis Poster. https://www.sans.org/posters/windows-forensic-analysis/.

Póster publicado por SANS sobre elementos de interés en Sistemas Operativos Windows.

© Universidad Internacional de La Rioja (UNIR)

How does Apple's M1 chipsets impact on imaging macs?

SUMURI Forensics. (2020). *How does Apple's M1 chipsets impact on imaging macs? Sumuri.* [Vídeo]. YouTube. https://www.youtube.com/watch?v=rgfYuuAUU8A.

Vídeo en el que se aborda el impacto del chip de cifrado M1 de Apple durante el proceso de adquisición de las imágenes forenses.

© Universidad Internacional de La Rioja (UNIR)

La práctica de la Informática Forense

Sandfly Security. (2018). *Simple Linux Forensics Christchurch Hacker Con 2017 With Craig Rowland From Sandfly Security.* [Vídeo]. YouTube. https://www.youtube.com/watch?v=yoe8guwauCY.

Vídeo en el que el especialista Craig Rowland repasa las técnicas más sencillas que podemos utilizar para evaluar un sistema Linux.

© Universidad Internacional de La Rioja (UNIR)

Test

1. En un Sistema Windows podemos obtener los usuarios que han iniciado sesión utilizando las herramientas:

A. PsLoggedOn.

B. LogonSessions.

C. El comando «query user /server:$SERVER» de PowerShell.

D. Todas las anteriores son correctas.

2. Durante el análisis de un equipo sospechoso de estar infectado con un *malware:*

A. No analizamos las conexiones abiertas.

B. Analizamos las conexiones abiertas.

C. Analizamos las conexiones cerradas.

D. Ninguna de las anteriores es correcta.

3. ¿Qué es el registro de Windows?

A. El contenedor de los *logs* del sistema operativo.

B. Un archivo de intercambio del sistema.

C. Una gran base de datos jerárquica.

D. Ninguna de las anteriores es correcta.

4. ¿Qué es el registro de eventos de un Sistema Operativo Windows?

A. Un conjunto de archivos especiales en el que se registran los eventos que se producen en el sistema.

B. Un archivo de intercambio del sistema.

C. Una gran base de datos jerárquica.

D. Ninguna de las anteriores es correcta.

© Universidad Internacional de La Rioja (UNIR)

5. ¿Dónde se ubica la papelera de reciclaje en un S. O. Windows 10?

A. En «Recycler\{SID del usuario}».

B. Dentro de la carpeta «$Recycle.Bin», en la raíz del dispositivo.

C. Dentro de la carpeta «$Recycle.Bin», en la carpeta del usuario.

D. En «{SID del usuario}\Recycler».

6. ¿Que indica que en la columna de *password* del archivo «/etc/passwd» de un S.O. Linux tengamos una «x»?

A. Que la contraseña está en claro en el archivo «/etc/shadow».

B. Que la contraseña está encriptada en el archivo «/etc/shadow».

C. Que la contraseña está en claro en el archivo «/etc/passwd».

D. Que la contraseña está encriptada en el archivo «/etc/passwd».

7. ¿Dónde se almacena la mayoría de los archivos de *log* en un Sistema Operativo Linux?

A. En la carpeta del usuario *root.*

B. En la ruta «/tmp».

C. En la ruta «/var/log/».

D. Ninguna de las anteriores es correcta.

8. ¿Cómo podemos obtener la lista de usuarios que han iniciado sesión en un equipo con S. O. MacOS apagado?

A. Mediante el comando «last».

B. Analizando los archivos «/var/log/wtmp» y «/var/log/btmp».

C. Analizando el archivo «/var/run/utmpx».

D. Ninguna de las anteriores es correcta.

© Universidad Internacional de La Rioja (UNIR)

9. ¿Cómo podemos realizar el volcado de los procesos de un equipo con S. O. MacOS?

A. A través del directorio «/proc».

B. Analizando los archivos de la carpeta «/var/process».

C. A través del directorio «/proc/process».

D. Ninguna de las anteriores es correcta.

10. ¿Dónde se almacena la mayoría de los archivos de *log* en un sistema MacOS?

A. En la ruta «/var/log/».

B. En la ruta «/Library/Logs/».

C. En la ruta «/Users/[USUARIO]/Library/Logs».

D. Todas las anteriores son correctas.

© Universidad Internacional de La Rioja (UNIR)